

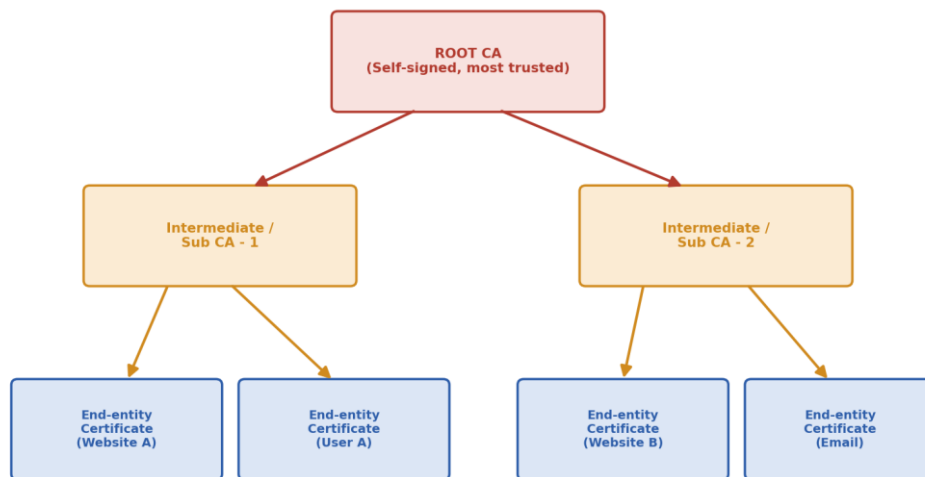
Prasad's Notes for PKI

PUBLIC KEY INFRASTRUCTURE

(PKI)

Complete Study Notes

PKI Trust Model — Certificate Hierarchy



This chain of trust is called a Certificate Chain. Trust flows downward from Root CA.

Table of Contents

1. Information Security, Security Attacks & Threats
2. Basic Encryption Concepts & File/Folder Encryption
3. Cryptographic Fundamentals, Ciphers & Protocols
4. Symmetric Key Encryption — DES, AES, RC5
5. Asymmetric Key Encryption — RSA, ECC
6. Diffie-Hellman Key Exchange & Attacks Against Encryption
7. Secure Hashing — SHA & HMAC
8. PKI Fundamentals — Digital Signature & Digital Certificate
9. Certificate Authority, Trust Model, Issuance & Revocation
10. Aadhaar e-Sign & Timestamping Services
11. Public Key Cryptography Standards — PKCS & FIPS 140-2
12. Strong Authentication — MFA, SSO, OAuth/OpenID
13. Authentication Protocols, FIDO & Zero Trust Architecture
14. Securing Websites & Emails — SSL, TLS, PGP, S/MIME
15. IT Act, LDAP/Active Directory & Introduction to Blockchain
16. Quick Revision Summary Sheet
17. Quiz — 40 Practice MCQs (Easy + Tricky)
18. Answer Key with Detailed Explanations

Chapter 1: Information Security, Security Attacks & Threats

1.1 What is Information Security?

Information Security means protecting information (data) from unauthorized access, use, disclosure, disruption, modification, or destruction. In simple words — it means keeping data safe, correct, and available only to the right people.

★ **IMPORTANT:** Information Security is not just about computers — it covers people, processes and technology together.

1.2 The CIA Triad — Three Goals of Security

Every security system is built to achieve three main goals, known together as the CIA Triad:

- **Confidentiality** — Only authorized people can view the data. (Achieved using encryption, access control, passwords).
- **Integrity** — Data must not be changed or tampered with, either accidentally or by an attacker. (Achieved using hashing, checksums, digital signatures).
- **Availability** — Data and systems must be accessible to authorized users whenever needed. (Achieved using backups, redundancy, DDoS protection).

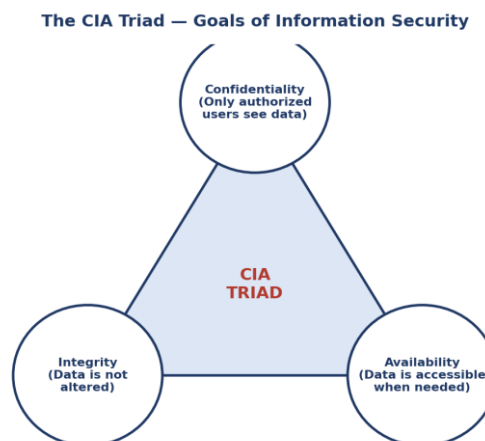


Figure 1.1 — The CIA Triad

1.3 Security Attacks

A security attack is any action that tries to break the CIA triad. Attacks are broadly divided into two types:

A. Passive Attacks

The attacker only observes or listens to data without changing it. Hard to detect because nothing is altered.

- Eavesdropping / Sniffing — secretly listening to network traffic.
- Traffic Analysis — studying patterns of communication (who talks to whom, how often) even if the content is encrypted.

B. Active Attacks

The attacker actually changes data, injects false data, or disrupts service. Easier to detect but more damaging.

- Masquerade — attacker pretends to be someone else (identity spoofing).
- Replay Attack — attacker captures a valid data transmission and re-sends it later to trick the system.
- Modification of Message — data is intercepted and altered before reaching the receiver.
- Denial of Service (DoS) — attacker floods a system with traffic so real users cannot use it.

1.4 Types of Threats

Threat Type	Description	Example
Malware	Malicious software designed to harm systems	Virus, Worm, Trojan, Ransomware
Phishing	Fake emails/websites tricking users into giving data	Fake bank login page
Man-in-the-Middle (MITM)	Attacker secretly sits between two parties	Intercepting Wi-Fi traffic
Insider Threat	Authorized person misuses access	Employee leaking company data
Social Engineering	Manipulating people psychologically	Pretending to be IT support on call

★ **IMPORTANT:** Exam tip: Passive attacks affect **CONFIDENTIALITY**; Active attacks affect **INTEGRITY** and **AVAILABILITY**.

Chapter 2: Basic Encryption Concepts & File/Folder Encryption

2.1 What is Encryption?

Encryption is the process of converting readable data (plaintext) into an unreadable, scrambled form (ciphertext) using a mathematical algorithm and a key. Only someone with the correct key can decrypt it back to plaintext.

- **Plaintext** — the original, readable message.
- **Ciphertext** — the scrambled, unreadable message.
- **Key** — a secret value used by the algorithm to encrypt/decrypt.
- **Algorithm / Cipher** — the mathematical procedure used for encryption.

2.2 File Encryption

File encryption protects individual files by converting their contents into ciphertext so that even if the file is stolen or copied, it cannot be read without the decryption key. Common tools include VeraCrypt, BitLocker, and built-in OS tools.

2.3 Encrypting Folders (Graphical / using cipher command)

Windows provides EFS (Encrypting File System) that lets a user encrypt a folder graphically (right-click → Properties → Advanced → Encrypt contents) or via the command-line 'cipher' tool. Once encrypted, only the user account (or a designated recovery agent) that encrypted it can open the files.

- Graphical method: File/Folder Properties → Advanced → 'Encrypt contents to secure data'.
- Command-line method: the 'cipher /e' command encrypts a folder; 'cipher /d' decrypts it.

★ **IMPORTANT:** EFS keys are tied to the Windows user account — if the account/profile is lost without a backup key, the encrypted files can become permanently unreadable.

Chapter 3: Cryptographic Fundamentals, Ciphers & Protocols

3.1 What is Cryptography?

Cryptography is the science of writing and solving codes — the study of techniques used to secure communication so that only the sender and intended receiver can understand the message.

3.2 Types of Cryptographic Ciphers

Feature	Symmetric Cipher	Asymmetric Cipher
Keys used	1 shared secret key	2 keys — Public & Private
Speed	Fast	Slower (heavy math)
Key distribution problem	Difficult (must share key secretly)	Easy (public key can be shared openly)
Examples	DES, AES, RC5	RSA, ECC
Best used for	Encrypting bulk data	Key exchange, digital signatures

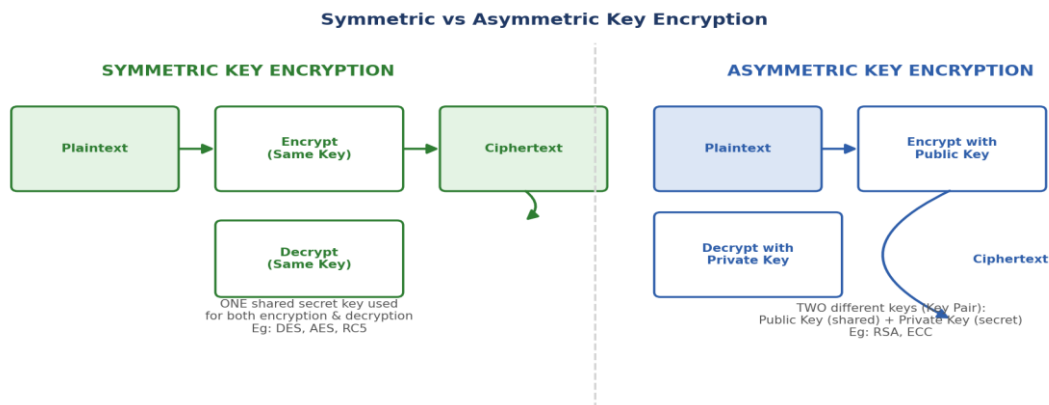


Figure 3.1 — Symmetric vs Asymmetric Encryption

3.3 Cryptographic Protocols — History, Usage & Key Generation

A cryptographic protocol is an agreed step-by-step procedure that uses cryptographic algorithms to achieve a security goal, such as secure key exchange, authentication, or confidential messaging.

- **History:** Cryptography began with simple substitution ciphers (like the Caesar Cipher used by Julius Caesar) and evolved through mechanical machines (like Enigma in WWII) to today's complex mathematical algorithms.
- **Usage:** Protocols define how two parties agree on algorithms, exchange or generate keys, and encrypt/authenticate messages — for example the TLS protocol used to secure websites.
- **Key Generation:** Keys are generated using random or pseudo-random number generators. Strong keys must be sufficiently long and unpredictable.
- **Ciphering Message:** Once keys are ready, the plaintext message is passed through the chosen cipher algorithm along with the key to produce ciphertext for transmission.

Chapter 4: Symmetric Key Encryption — DES, AES, RC5

In symmetric key encryption, the SAME key is used for both encryption and decryption. Both sender and receiver must securely share this one secret key beforehand.

4.1 DES (Data Encryption Standard)

- Developed by IBM, adopted as a US standard in 1977.
- Uses a 64-bit block size and a 56-bit key (the remaining 8 bits are for parity/error-checking).
- Now considered WEAK and insecure because 56-bit keys can be brute-forced with modern computing power.
- Triple DES (3DES) applies DES three times with different keys to improve security, but it is much slower.

4.2 AES (Advanced Encryption Standard)

- Replaced DES as the official US government standard in 2001.
- Uses a 128-bit block size with key sizes of 128, 192, or 256 bits.
- Fast, efficient, and currently considered highly secure — used worldwide (Wi-Fi WPA2/3, VPNs, disk encryption).

4.3 RC5

- Designed by Ronald Rivest (the 'R' in RSA) in 1994.
- A simple, fast block cipher with variable block size, key size, and number of rounds — making it flexible for different security needs.

★ **IMPORTANT:** Exam tip: Remember the key sizes — DES = 56-bit, AES = 128/192/256-bit. AES is the modern replacement for DES.

Chapter 5: Asymmetric Key Encryption — RSA, ECC

In asymmetric (public key) encryption, TWO mathematically related keys are used — a Public Key (shared openly with everyone) and a Private Key (kept secret by the owner). Data encrypted with one key can only be decrypted with the other key of the pair.

5.1 RSA (Rivest–Shamir–Adleman)

- Invented in 1977 by Rivest, Shamir, and Adleman — the most widely used asymmetric algorithm.
- Security is based on the mathematical difficulty of factoring the product of two very large prime numbers.
- Common key sizes: 1024-bit (weak now), 2048-bit and 4096-bit (recommended today).
- Used for secure key exchange, digital signatures, and SSL/TLS certificates.

5.2 ECC (Elliptic Curve Cryptography)

- Based on the mathematics of elliptic curves over finite fields.
- Provides the SAME level of security as RSA but with a MUCH SMALLER key size (e.g., a 256-bit ECC key is roughly as strong as a 3072-bit RSA key).
- Faster and uses less processing power/battery — ideal for mobile devices and IoT.

★ **IMPORTANT:** Exam tip: ECC = smaller keys, same security, faster performance — this is the most common comparison question between RSA and ECC.

Chapter 6: Diffie-Hellman Key Exchange & Attacks Against Encryption

6.1 Diffie-Hellman (DH) Key Exchange

Diffie-Hellman is a method that allows two parties who have never met before to agree on a shared SECRET key over a public (insecure) channel — WITHOUT ever sending the secret key itself over the network.

Both sides start with a public prime number (p) and base (g) that even an attacker can see. Each side picks a secret private number, computes a public value using it, and exchanges only that public value. Using their own private number plus the other party's public value, both sides independently arrive at the SAME shared secret.

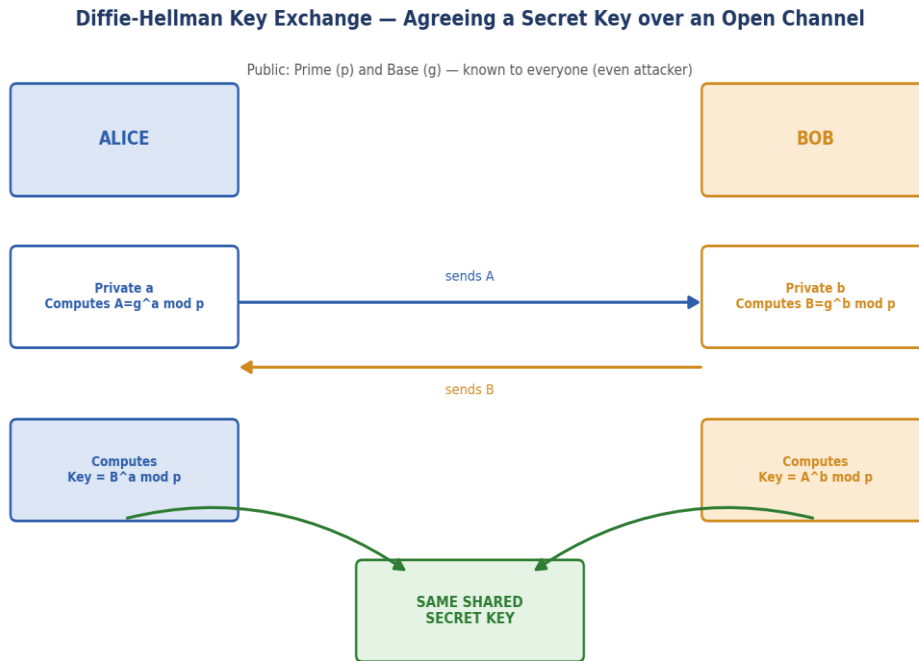


Figure 6.1 — Diffie-Hellman Key Exchange

★ **IMPORTANT:** Diffie-Hellman solves the 'key distribution problem' of symmetric encryption — it lets two strangers create a shared secret key without ever transmitting the key itself.

6.2 Attacks Against Encryption

Attack Type	How It Works
Brute Force Attack	Attacker tries every possible key until the right one is found
Man-in-the-Middle (MITM)	Attacker secretly intercepts and possibly alters the DH exchange between two parties
Chosen Plaintext Attack	Attacker gets the system to encrypt data of their choice to learn about the key
Known Plaintext Attack	Attacker has some plaintext & matching ciphertext pairs and tries to deduce the key
Side-Channel Attack	Attacker studies power usage, timing, or sound of a device to leak key information

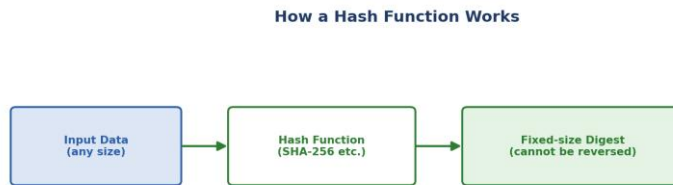
6.3 Common Cryptographic Issues

- Weak or short keys that can be brute-forced easily.
- Reusing the same key/IV (Initialization Vector) repeatedly, which weakens security.
- Poor random number generation, making keys predictable.
- Using outdated or broken algorithms (like DES or MD5) instead of modern standards.
- Not protecting the private key properly (storing it in plaintext).

Chapter 7: Secure Hashing — SHA & HMAC

7.1 What is Hashing?

Hashing is a ONE-WAY mathematical function that converts input data of ANY size into a fixed-size string of characters, called a hash value or digest. Unlike encryption, hashing CANNOT be reversed to get back the original data.



One-way process: same input -> same hash always. Used to check INTEGRITY, not secrecy.

Figure 7.1 — How a Hash Function Works

Key Properties of a Good Hash Function

- Deterministic — same input always gives the same hash.
- Fast to compute.
- Pre-image resistant — cannot reverse the hash to find the original input.
- Collision resistant — extremely unlikely for two different inputs to produce the same hash.
- Avalanche effect — a tiny change in input drastically changes the output hash.

7.2 SHA (Secure Hash Algorithm)

- A family of hash functions published by NIST (US government).
- SHA-1 produces a 160-bit hash — now considered WEAK and broken (collisions found).
- SHA-2 family (SHA-256, SHA-512) is widely used today and considered secure.
- SHA-3 is the newest family, based on a different internal design (Keccak) for extra security diversity.

7.3 HMAC (Hash-based Message Authentication Code)

HMAC combines a hash function (like SHA-256) WITH a secret key to verify both the integrity AND authenticity of a message. Unlike a plain hash, an attacker without the secret key cannot forge a valid HMAC even if they know the hash algorithm used.

★ **IMPORTANT:** Hashing alone only proves data has not changed. HMAC additionally proves WHO sent it, because it needs the secret key.

7.4 Encryption vs Hashing

Aspect	Encryption	Hashing
Purpose	Confidentiality (keep data secret)	Integrity (detect tampering)
Reversible?	Yes, with the correct key	No — one-way only
Output size	Similar to input size	Fixed size, regardless of input size
Example	AES, RSA	SHA-256, MD5

Chapter 8: PKI Fundamentals — Digital Signature & Digital Certificate

8.1 What is a Digital Signature?

A digital signature is the electronic equivalent of a handwritten signature. It uses asymmetric cryptography to prove that a message really came from the claimed sender (authentication) and was not altered (integrity), and the sender cannot later deny sending it (non-repudiation).

How a Digital Signature Works

- **Signing (sender side):** The message is hashed to create a digest. The digest is then encrypted using the SENDER's PRIVATE key — this encrypted digest is the digital signature.
- **Verification (receiver side):** The receiver hashes the received message again, and separately decrypts the received signature using the SENDER's PUBLIC key. If both digests MATCH, the signature is valid.

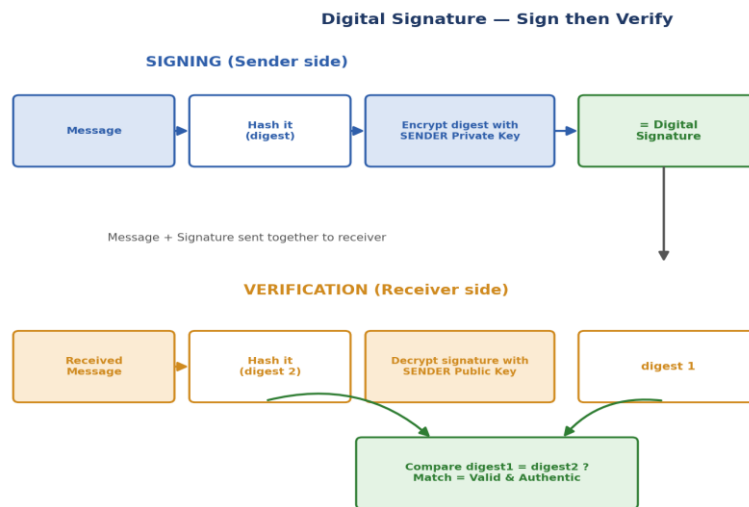


Figure 8.1 — Digital Signature: Sign then Verify

★ **IMPORTANT:** A digital signature is created with the sender's **PRIVATE** key and verified with the sender's **PUBLIC** key — this is the opposite of normal encryption for confidentiality (which encrypts with the receiver's public key).

Three Properties Provided by Digital Signatures

- **Authentication** — confirms who sent the message.
- **Integrity** — confirms the message was not modified.
- **Non-repudiation** — the sender cannot deny having sent it.

8.2 What is a Digital Certificate?

A digital certificate is an electronic document that binds a public key to the identity of its owner (a person, organization, or website), and is digitally signed by a trusted third party called a Certificate Authority (CA). It works like an electronic ID card that proves 'this public key really belongs to this entity.'

Contents of a Typical Digital Certificate (X.509 format)

Field	Meaning
Subject	The entity (person/site) the certificate is issued to
Public Key	The subject's public key

Field	Meaning
Issuer	The CA that issued and signed the certificate
Validity Period	Start date and expiry date
Serial Number	Unique ID assigned by the CA
Digital Signature	CA's signature proving the certificate's authenticity

Chapter 9: Certificate Authority, Trust Model, Issuance & Revocation

9.1 Certificate Authority (CA)

A Certificate Authority (CA) is a trusted organization that verifies the identity of an entity and issues digital certificates binding that entity's identity to a public key. Examples: DigiCert, Sectigo, GlobalSign, eMudhra (India).

9.2 Trust Model — Certificate Hierarchy

Trust in PKI flows from a Root CA down through Intermediate/Sub CAs to end-user certificates — this is called a Certificate Chain or Chain of Trust. The Root CA's own certificate is self-signed and is trusted because it is pre-installed in operating systems and browsers.

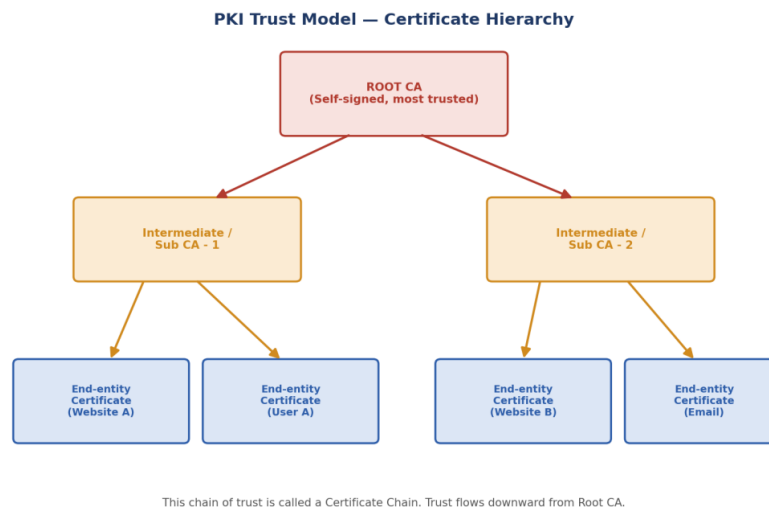


Figure 9.1 — PKI Certificate Hierarchy / Trust Model

★ **IMPORTANT:** If any certificate in the chain (Root, Intermediate, or End-entity) is invalid or expired, the browser will show a 'certificate not trusted' warning.

9.3 Certificate Issuance Process

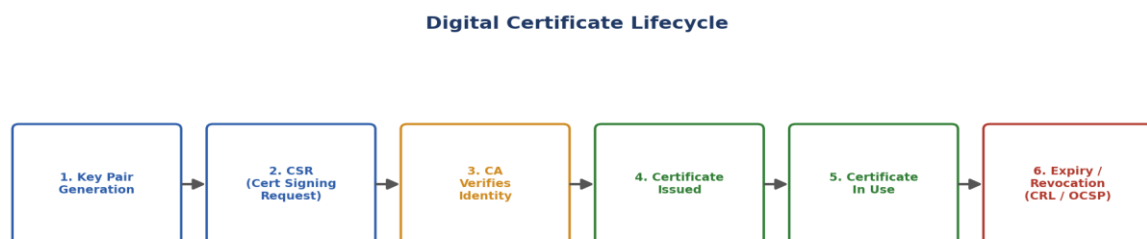


Figure 9.2 — Digital Certificate Lifecycle

- Key Pair Generation — the applicant generates a public/private key pair.
- CSR (Certificate Signing Request) — the applicant sends the public key + identity details to the CA.
- Identity Verification — CA verifies the applicant is really who they claim to be.

- Certificate Issuance — CA signs and issues the digital certificate.
- Usage — the certificate is used (e.g., installed on a web server for HTTPS).
- Expiry/Revocation — the certificate eventually expires or may be revoked earlier if compromised.

9.4 Certificate Revocation — CRL & OCSP

Sometimes a certificate must be cancelled before its expiry date — for example if the private key is stolen. This is called revocation.

Method	How It Works	Drawback
CRL (Certificate Revocation List)	CA publishes a downloadable list of all revoked certificate serial numbers	List can be large; not real-time
OCSP (Online Certificate Status Protocol)	Client asks the CA in real-time: 'Is this certificate still valid?'	Requires the CA server to be online and reachable

9.5 Types and Classes of Certificates

Type	Validation Level	Used For
DV (Domain Validation)	Only proves ownership of the domain	Blogs, small websites
OV (Organization Validation)	Verifies the organization's identity too	Business websites
EV (Extended Validation)	Strictest checks on the legal entity	Banks, e-commerce, high trust sites
Class 1 Certificate	Basic email address validation	Personal email security
Class 2/3 Certificate	Identity & organization verification	Business & legal documents, e-Sign

Chapter 10: Aadhaar e-Sign & Timestamping Services

10.1 Aadhaar and e-Sign

e-Sign is an online electronic signature service in India that lets a person digitally sign a document using their Aadhaar number, authenticated via OTP or biometric verification, without needing a physical USB token or smart card.

- The user's identity is verified through UIDAI (Aadhaar database) using OTP/biometric.
- A licensed CA instantly issues a short-validity digital certificate to complete the signing.
- Legally recognized under the Indian IT Act, 2000, making it valid for many official and legal documents.

★ IMPORTANT: Aadhaar e-Sign makes digital signatures accessible to ordinary citizens instantly and paperlessly, without needing to buy and manage a physical crypto token.

10.2 Time Stamping Services

A timestamp is a trusted, verifiable record of the exact date and time a document was digitally signed or a transaction occurred. It is issued by a trusted Time Stamping Authority (TSA).

- Proves that a document existed and was signed at a specific point in time.
- Prevents disputes such as 'the certificate had already expired when this was signed' — the timestamp shows the signature was valid at the time it was made.
- Important for legal validity of digital signatures, especially in long-term document archiving.

Chapter 11: Public Key Cryptography Standards — PKCS & FIPS 140-2

11.1 PKCS (Public Key Cryptography Standards)

PKCS is a set of standards developed by RSA Laboratories that define how public key cryptography should be implemented, so that different systems and vendors work together (interoperability).

Standard	Purpose
PKCS #1	RSA encryption standard
PKCS #7	Format for signed/encrypted messages (Cryptographic Message Syntax)
PKCS #10	Format for a Certificate Signing Request (CSR)
PKCS #12	Format for storing a private key + certificate together in one password-protected file (.pfx / .p12)

★ **IMPORTANT:** PKCS#10 is used to **REQUEST** a certificate (CSR); PKCS#12 is used to **STORE**/carry a private key + certificate together — a very common exam comparison.

11.2 FIPS 140-2

FIPS 140-2 (Federal Information Processing Standard) is a US government security standard that specifies requirements for cryptographic modules (hardware and software) — defining how securely keys must be generated, stored, and used.

- Defines 4 increasing security levels (Level 1 = lowest, Level 4 = highest physical/logical protection).
- Widely used as a benchmark to certify that hardware security modules (HSMs) and crypto software are trustworthy.

Chapter 12: Strong Authentication — MFA, SSO, OAuth/OpenID

12.1 Strong Authentication

Strong authentication means proving a user's identity using more reliable methods than a simple password alone, to reduce the risk of unauthorized access.

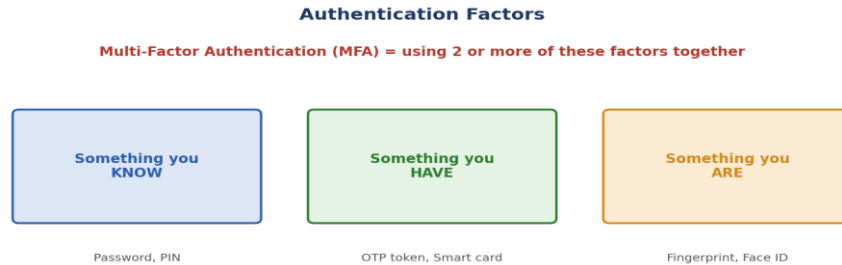


Figure 12.1 — The Three Authentication Factors

12.2 Single-Factor vs Multi-Factor Authentication

Type	Description	Example
Single Factor Authentication (SFA)	Only ONE factor is used to verify identity	Just a password
Multi-Factor Authentication (MFA)	TWO or more different factors are combined	Password + OTP on phone

★ **IMPORTANT:** MFA must combine **DIFFERENT** factor types (know + have, or know + are). Two passwords together are still Single Factor, not MFA!

12.3 Single Sign-On (SSO)

SSO allows a user to log in ONCE and gain access to multiple different applications/systems without having to log in again for each one. This improves user convenience and reduces password fatigue, while centralizing authentication.

12.4 OpenID and OAuth

Protocol	Purpose	Simple Example
OpenID	AUTHENTICATION — proves WHO you are	'Login with Google' to sign in to a website
OAuth	AUTHORIZATION — grants limited ACCESS to your data without sharing your password	Allowing an app to read your Google Calendar

★ **IMPORTANT:** Easy way to remember: OpenID = 'who are you' (login), OAuth = 'what can you access' (permission).

12.5 Graphical Passwords

A graphical password authentication method asks the user to select images, points on a picture, or draw a pattern instead of typing text — often easier to remember and can resist certain attacks like simple keylogging, though they can be vulnerable to shoulder-surfing.

Chapter 13: Authentication Protocols, FIDO & Zero Trust Architecture

13.1 Common Authentication Protocols

- Kerberos — uses a trusted third party (Key Distribution Center) and encrypted 'tickets' to authenticate users on a network without repeatedly sending passwords.
- RADIUS — a client/server protocol that centralizes authentication, authorization, and accounting (AAA) for network access.
- LDAP-based authentication — verifies user credentials by checking against a central directory service.

13.2 FIDO Authentication

FIDO (Fast IDentity Online) is an open authentication standard that replaces passwords with cryptographic key pairs generated on the user's own device (like a security key, fingerprint, or PIN). The private key never leaves the user's device, making it highly resistant to phishing and password-database breaches.

13.3 Zero Trust Architecture (ZTA)

Zero Trust is a modern security model based on the principle: 'Never trust, always verify.' Unlike older models that trusted anything inside the company network automatically, Zero Trust assumes NO user or device should be trusted by default — every single access request must be continuously verified, regardless of location.

- Core Principle: Verify explicitly — check identity, device, and context every time.
- Core Principle: Use least-privilege access — give users only the minimum access they need.
- Core Principle: Assume breach — design systems as if an attacker is already inside.

★ IMPORTANT: Zero Trust removes the old idea of a safe 'internal network' — every request is treated as if it comes from an open, untrusted network.

Chapter 14: Securing Websites & Emails — SSL, TLS, PGP, S/MIME

14.1 SSL and TLS

SSL (Secure Sockets Layer) and its modern successor TLS (Transport Layer Security) are protocols that create an encrypted connection between a client (browser) and a server (website), protecting data in transit. TLS is more secure and has replaced SSL, though people still commonly say 'SSL certificate' out of habit.



Figure 14.1 — Simplified SSL/TLS Handshake

- HTTPS = HTTP + TLS/SSL — the padlock icon in a browser shows the connection is secured with TLS.
- TLS uses asymmetric encryption (via the certificate) to safely exchange a symmetric session key, then uses fast symmetric encryption for the actual data transfer — combining the strengths of both.

14.2 PGP (Pretty Good Privacy)

PGP is an email/data encryption program that combines symmetric and asymmetric cryptography to provide confidentiality, integrity, and authentication for emails and files. It uses a 'Web of Trust' model — users personally verify and sign each other's keys, instead of relying on centralized CAs.

14.3 S/MIME (Secure/Multipurpose Internet Mail Extensions)

S/MIME is another standard for encrypting and digitally signing emails, but unlike PGP's Web of Trust, it relies on the traditional CA-based PKI trust model (certificates issued by a Certificate Authority).

Feature	PGP	S/MIME
Trust Model	Web of Trust (peer verification)	PKI / Certificate Authority (CA)
Common Use	Personal email encryption, files	Corporate/enterprise email encryption
Setup	Users exchange & sign keys manually	Certificates issued centrally by a CA

Chapter 15: IT Act, LDAP/Active Directory & Introduction to Blockchain

15.1 The IT Act, 2000 (India)

The Information Technology Act, 2000 is India's primary law governing cybercrime and electronic commerce. It gives LEGAL RECOGNITION to digital signatures and electronic records, making them as valid as handwritten signatures and paper documents in most cases.

- Section 3 — deals with the authentication of electronic records using digital signatures.
- Recognizes Certifying Authorities (CAs) licensed by the Controller of Certifying Authorities (CCA) in India.
- Provides penalties for cybercrimes such as hacking, identity theft, and data breaches.

15.2 LDAP / Active Directory

LDAP (Lightweight Directory Access Protocol) is a protocol used to access and manage directory information — such as usernames, passwords, and organizational data — stored in a central directory server.

Active Directory (AD) is Microsoft's implementation of a directory service that uses LDAP. It is widely used in organizations to centrally manage users, computers, permissions, and authentication across a network.

15.3 Introduction to Blockchain

A blockchain is a distributed, tamper-resistant digital ledger where data is stored in linked 'blocks,' each containing a cryptographic hash of the previous block. This chaining makes it extremely difficult to alter past records without detection.

- Decentralized — no single central authority controls the ledger; it is maintained across many computers (nodes).
- Uses cryptographic hashing and, often, digital signatures — directly connecting it to PKI concepts studied in this syllabus.
- Applications: Cryptocurrency (Bitcoin), supply chain tracking, secure record-keeping, smart contracts.

★ IMPORTANT: Blockchain relies heavily on hashing (to link blocks) and digital signatures (to authorize transactions) — both core PKI concepts.

Chapter 16: Quick Revision Summary Sheet

Use this one-page summary the night before your exam to quickly recall key terms.

Term	One-Line Meaning
CIA Triad	Confidentiality, Integrity, Availability — the 3 goals of security
Symmetric Encryption	Same key for encryption & decryption (DES, AES, RC5)
Asymmetric Encryption	Public + Private key pair (RSA, ECC)
Diffie-Hellman	Securely agree on a shared secret key over an open channel
Hashing	One-way fixed-size digest used to check integrity (SHA)
HMAC	Hash + secret key = integrity + authenticity
Digital Signature	Sign with sender's private key, verify with sender's public key
Digital Certificate	Electronic ID binding a public key to an identity, signed by a CA
CA (Certificate Authority)	Trusted body that issues & signs digital certificates
CRL	List of revoked certificates published by a CA
OCSP	Real-time online check of a certificate's revocation status
PKCS#10	Format of a Certificate Signing Request (CSR)
PKCS#12	File storing private key + certificate together (.pfx/.p12)
FIPS 140-2	US standard for security of cryptographic hardware/software modules
MFA	Two or more DIFFERENT authentication factors combined
OpenID	Protocol for AUTHENTICATION (who you are)
OAuth	Protocol for AUTHORIZATION (what you can access)
FIDO	Passwordless authentication using device-based key pairs
Zero Trust	'Never trust, always verify' — no default trust for any user/device
SSL/TLS	Protocols that encrypt data between browser and website (HTTPS)
PGP	Email encryption using Web of Trust model
S/MIME	Email encryption using CA-based PKI trust model
IT Act 2000	Indian law giving legal validity to digital signatures
Blockchain	Tamper-resistant distributed ledger using hashing & signatures

Chapter 17: Quiz — 40 Practice MCQs

Instructions: Attempt all 40 questions. Difficulty is mixed — some are easy recall questions, some are tricky and test deeper understanding. Answers and explanations are given in the next chapter. Try to answer WITHOUT looking at the answer key first! (Read It)

Q1. What does the 'C' in the CIA Triad stand for?

- A) Cryptography
- B) Confidentiality
- C) Certification
- D) Control

Q2. Which of these is a PASSIVE attack?

- A) Replay attack
- B) Denial of Service
- C) Eavesdropping
- D) Message modification

Q3. Which Windows feature lets a user encrypt a folder graphically or via the 'cipher' command?

- A) BitLocker
- B) EFS (Encrypting File System)
- C) Windows Defender
- D) VPN

Q4. In symmetric key encryption, how many keys are used for encryption and decryption combined?

- A) One shared key
- B) Two different keys
- C) Three keys
- D) No key needed

Q5. What is the key size used by DES (Data Encryption Standard)?

- A) 40-bit
- B) 56-bit
- C) 128-bit
- D) 256-bit

Q6. Which algorithm officially replaced DES as the US government encryption standard?

- A) RC5
- B) 3DES
- C) AES
- D) RSA

Q7. RC5 was designed by:

- A) Whitfield Diffie
- B) Ronald Rivest
- C) Martin Hellman
- D) Bruce Schneier

Q8. The security of RSA encryption is based on the difficulty of:

- A) Solving elliptic curve equations
- B) Factoring the product of two large prime numbers
- C) Reversing a hash function
- D) Guessing a symmetric key

Q9. Compared to RSA, the main advantage of ECC (Elliptic Curve Cryptography) is:

- A) It does not need a private key
- B) It provides equal security with a much smaller key size
- C) It cannot be broken by any attack

D) It uses no mathematics

Q10. What is the main purpose of the Diffie-Hellman protocol?

- A) To hash a message
- B) To securely agree on a shared secret key over an open channel
- C) To digitally sign a document
- D) To revoke a certificate

Q11. An attacker who tries every possible key until the correct one is found is performing a:

- A) Replay attack
- B) Brute force attack
- C) Man-in-the-middle attack
- D) Phishing attack

Q12. Which statement about hashing is TRUE?

- A) Hashing is reversible with the right key
- B) A good hash function should be collision resistant
- C) Hash output size grows with input size
- D) Hashing provides confidentiality of data

Q13. SHA-1 produces a hash value of what length?

- A) 128-bit
- B) 160-bit
- C) 256-bit
- D) 512-bit

Q14. HMAC improves on plain hashing by adding:

- A) A digital certificate
- B) A secret key
- C) A timestamp
- D) A random IV

Q15. A digital signature is created by encrypting the message digest with the sender's:

- A) Public key
- B) Private key
- C) Session key
- D) Symmetric key

Q16. To verify a digital signature, the receiver uses the sender's:

- A) Private key
- B) Public key
- C) Password
- D) Session key

Q17. Which of these is NOT a property directly provided by a digital signature?

- A) Authentication
- B) Integrity
- C) Confidentiality
- D) Non-repudiation

Q18. A digital certificate mainly binds a public key to:

- A) A password
- B) An IP address
- C) An identity (person/organization/website)
- D) A session key

Q19. Who is responsible for verifying identity and issuing digital certificates?

- A) ISP
- B) Certificate Authority (CA)

- C) DNS server
- D) Firewall

Q20. A Root CA's own certificate is typically:

- A) Issued by a Sub CA
- B) Self-signed
- C) Never trusted by browsers
- D) Expired by default

Q21. CRL stands for:

- A) Certificate Renewal List
- B) Certified Root List
- C) Certificate Revocation List
- D) Cryptographic Report Log

Q22. Which certificate revocation-checking method works in real time online?

- A) CRL
- B) OCSP
- C) PKCS#12
- D) CSR

Q23. Which type of SSL certificate involves the STRICTEST identity verification?

- A) DV (Domain Validation)
- B) OV (Organization Validation)
- C) EV (Extended Validation)
- D) Self-signed

Q24. Aadhaar e-Sign verifies a user's identity mainly through:

- A) A physical USB token only
- B) OTP or biometric verification via UIDAI
- C) A handwritten signature scan
- D) A CAPTCHA

Q25. The main purpose of a trusted timestamp on a digital signature is to:

- A) Make the file smaller
- B) Prove the signature was made at a specific valid time
- C) Encrypt the document
- D) Replace the need for a certificate

Q26. Which PKCS standard defines the format of a Certificate Signing Request (CSR)?

- A) PKCS#1
- B) PKCS#7
- C) PKCS#10
- D) PKCS#12

Q27. Which PKCS standard is used to store a private key together with its certificate in one password-protected file?

- A) PKCS#1
- B) PKCS#7
- C) PKCS#10
- D) PKCS#12

Q28. FIPS 140-2 is a standard that defines security requirements for:

- A) Website design
- B) Cryptographic hardware and software modules
- C) Email formatting
- D) Network cabling

Q29. Which of the following is a TRUE example of Multi-Factor Authentication (MFA)?

- A) Two different passwords
- B) A password plus an OTP sent to your phone
- C) Typing your password twice
- D) Using a longer password

Q30. OpenID is primarily used for:

- A) Authorization to access data
- B) Authentication — proving who you are
- C) Encrypting emails
- D) Revoking certificates

Q31. OAuth is primarily used for:

- A) Authentication only
- B) Granting limited authorization/access to resources
- C) Hashing passwords
- D) Issuing digital certificates

Q32. FIDO authentication mainly aims to:

- A) Increase password length requirements
- B) Eliminate the need for traditional passwords using device-based keys
- C) Replace CAs with blockchain
- D) Encrypt network traffic only

Q33. The Zero Trust Architecture principle can be summarized as:

- A) Trust all internal network traffic
- B) Never trust, always verify
- C) Trust but don't verify
- D) Verify once, trust forever

Q34. In an SSL/TLS handshake, after verifying the certificate, the client and server mainly agree on a:

- A) New Root CA
- B) Session (symmetric) key for the rest of the communication
- C) New IP address
- D) New domain name

Q35. HTTPS is essentially:

- A) HTTP without any encryption
- B) HTTP combined with SSL/TLS encryption
- C) A type of firewall
- D) A DNS security extension

Q36. PGP (Pretty Good Privacy) uses which trust model?

- A) Centralized CA-based PKI
- B) Web of Trust
- C) Zero Trust
- D) Kerberos-based trust

Q37. S/MIME differs from PGP mainly because S/MIME relies on:

- A) No encryption at all
- B) A CA-based PKI trust model
- C) Only symmetric encryption
- D) Blockchain verification

Q38. Under India's IT Act, 2000, digital signatures are:

- A) Not legally valid
- B) Legally recognized, similar to handwritten signatures
- C) Valid only for government use
- D) Valid only outside India

Q39. Blockchain achieves tamper-resistance mainly through the use of:

- A) Firewalls
- B) Cryptographic hashing linking each block to the previous one
- C) Antivirus software
- D) VPN tunnels

Q40. Which best describes the relationship between LDAP and Active Directory?

- A) They are unrelated technologies
- B) Active Directory is Microsoft's directory service that uses the LDAP protocol
- C) LDAP is a type of digital certificate
- D) Active Directory replaced all use of PKI

Chapter 18: Answer Key with Detailed Explanations

Check your answers below. Read every explanation, even for questions you got right — it will help you understand the CONCEPT, not just memorize the answer.

Q1. What does the 'C' in the CIA Triad stand for?

Correct Answer: B) Confidentiality

Explanation: CIA Triad = Confidentiality, Integrity, Availability — the three core goals of information security.

Q2. Which of these is a PASSIVE attack?

Correct Answer: C) Eavesdropping

Explanation: Eavesdropping only observes data without altering it, making it passive. The other three actively change or disrupt data/service.

Q3. Which Windows feature lets a user encrypt a folder graphically or via the 'cipher' command?

Correct Answer: B) EFS (Encrypting File System)

Explanation: EFS is Windows' built-in feature for encrypting individual files/folders, accessible via Properties > Advanced or the 'cipher' command-line tool.

Q4. In symmetric key encryption, how many keys are used for encryption and decryption combined?

Correct Answer: A) One shared key

Explanation: Symmetric encryption uses ONE shared secret key for both encrypting and decrypting the data.

Q5. What is the key size used by DES (Data Encryption Standard)?

Correct Answer: B) 56-bit

Explanation: DES uses a 56-bit effective key (64 bits total, with 8 parity bits), now considered too weak against brute-force attacks.

Q6. Which algorithm officially replaced DES as the US government encryption standard?

Correct Answer: C) AES

Explanation: AES (Advanced Encryption Standard) replaced DES in 2001 and supports 128/192/256-bit keys.

Q7. RC5 was designed by:

Correct Answer: B) Ronald Rivest

Explanation: RC5 was designed by Ronald Rivest — the same 'R' from RSA — in 1994.

Q8. The security of RSA encryption is based on the difficulty of:

Correct Answer: B) Factoring the product of two large prime numbers

Explanation: RSA's strength comes from how computationally hard it is to factor a very large number back into its two original prime factors.

Q9. Compared to RSA, the main advantage of ECC (Elliptic Curve Cryptography) is:

Correct Answer: B) It provides equal security with a much smaller key size

Explanation: ECC achieves the same security level as RSA using far smaller keys, making it faster and more efficient — ideal for mobile/IoT devices.

Q10. What is the main purpose of the Diffie-Hellman protocol?

Correct Answer: B) To securely agree on a shared secret key over an open channel

Explanation: Diffie-Hellman lets two parties who have never met create a common secret key even while an attacker is watching the channel.

Q11. An attacker who tries every possible key until the correct one is found is performing a:

Correct Answer: B) Brute force attack

Explanation: A brute force attack systematically tries all possible key combinations until it finds the correct one.

Q12. Which statement about hashing is TRUE?

Correct Answer: B) A good hash function should be collision resistant

Explanation: A strong hash function must be collision-resistant (two different inputs should not give the same hash). Hashing is one-way (irreversible) and always produces a FIXED-size output, and it protects integrity, not confidentiality.

Q13. SHA-1 produces a hash value of what length?

Correct Answer: B) 160-bit

Explanation: SHA-1 produces a 160-bit digest. It is now considered broken/weak; SHA-256 (SHA-2 family) is preferred today.

Q14. HMAC improves on plain hashing by adding:

Correct Answer: B) A secret key

Explanation: HMAC = Hash function + a secret key, giving both integrity AND authenticity, since only someone with the key can produce a valid HMAC.

Q15. A digital signature is created by encrypting the message digest with the sender's:

Correct Answer: B) Private key

Explanation: The sender signs by encrypting the hash/digest with their OWN PRIVATE key. Anyone can then verify it using the sender's public key.

Q16. To verify a digital signature, the receiver uses the sender's:

Correct Answer: B) Public key

Explanation: Verification uses the sender's PUBLIC key to decrypt the signature and compare it against a freshly computed hash of the message.

Q17. Which of these is NOT a property directly provided by a digital signature?

Correct Answer: C) Confidentiality

Explanation: Digital signatures prove who sent a message (authentication), that it wasn't altered (integrity), and prevent denial (non-repudiation) — but they do NOT by themselves keep the message secret (confidentiality), since signatures don't hide the content.

Q18. A digital certificate mainly binds a public key to:

Correct Answer: C) An identity (person/organization/website)

Explanation: A digital certificate confirms that a specific public key really belongs to a specific identity, verified and signed by a CA.

Q19. Who is responsible for verifying identity and issuing digital certificates?

Correct Answer: B) Certificate Authority (CA)

Explanation: A Certificate Authority (CA) is the trusted entity that checks identity and issues signed digital certificates.

Q20. A Root CA's own certificate is typically:

Correct Answer: B) Self-signed

Explanation: A Root CA certificate is self-signed — it signs its own certificate, and is trusted because it is pre-installed in OS/browser trust stores.

Q21. CRL stands for:

Correct Answer: C) Certificate Revocation List

Explanation: CRL (Certificate Revocation List) is a list of certificate serial numbers that a CA has revoked before their expiry.

Q22. Which certificate revocation-checking method works in real time online?

Correct Answer: B) OCSP

Explanation: OCSP (Online Certificate Status Protocol) lets a client ask the CA in real time whether a certificate is still valid, unlike the downloadable CRL list.

Q23. Which type of SSL certificate involves the STRICTEST identity verification?

Correct Answer: C) EV (Extended Validation)

Explanation: EV (Extended Validation) certificates require the deepest legal and organizational checks, typically used by banks and e-commerce sites.

Q24. Aadhaar e-Sign verifies a user's identity mainly through:

Correct Answer: B) OTP or biometric verification via UIDAI

Explanation: e-Sign authenticates the signer using Aadhaar-linked OTP or biometric verification through UIDAI, avoiding the need for a physical crypto token.

Q25. The main purpose of a trusted timestamp on a digital signature is to:

Correct Answer: B) Prove the signature was made at a specific valid time

Explanation: A timestamp proves exactly when a document was signed — important for legal validity, even if the certificate expires later.

Q26. Which PKCS standard defines the format of a Certificate Signing Request (CSR)?

Correct Answer: C) PKCS#10

Explanation: PKCS#10 defines the CSR format, which is what an applicant sends to a CA to request a certificate.

Q27. Which PKCS standard is used to store a private key together with its certificate in one password-protected file?

Correct Answer: D) PKCS#12

Explanation: PKCS#12 (.pfx/.p12) bundles a private key and its certificate together, commonly used to import/export certificates.

Q28. FIPS 140-2 is a standard that defines security requirements for:

Correct Answer: B) Cryptographic hardware and software modules

Explanation: FIPS 140-2 sets US government requirements for how securely cryptographic modules (like HSMs) generate, store and use keys.

Q29. Which of the following is a TRUE example of Multi-Factor Authentication (MFA)?

Correct Answer: B) A password plus an OTP sent to your phone

Explanation: MFA needs factors from DIFFERENT categories (know + have). Two passwords are still only 'something you know' — that's still single-factor.

Q30. OpenID is primarily used for:

Correct Answer: B) Authentication — proving who you are

Explanation: OpenID handles AUTHENTICATION ('Login with Google' proves your identity), while OAuth handles AUTHORIZATION (permission to access data).

Q31. OAuth is primarily used for:

Correct Answer: B) Granting limited authorization/access to resources

Explanation: OAuth allows an application limited access to a user's data/resources without sharing the user's password.

Q32. FIDO authentication mainly aims to:

Correct Answer: B) Eliminate the need for traditional passwords using device-based keys

Explanation: FIDO uses cryptographic key pairs generated and stored on the user's device (private key never leaves it), removing reliance on traditional passwords.

Q33. The Zero Trust Architecture principle can be summarized as:

Correct Answer: B) Never trust, always verify

Explanation: Zero Trust assumes no user or device is automatically trusted, even inside the corporate network — every request is continuously verified.

Q34. In an SSL/TLS handshake, after verifying the certificate, the client and server mainly agree on a:

Correct Answer: B) Session (symmetric) key for the rest of the communication

Explanation: After certificate verification (asymmetric step), TLS switches to a fast symmetric session key for actual data encryption.

Q35. HTTPS is essentially:

Correct Answer: B) HTTP combined with SSL/TLS encryption

Explanation: HTTPS = HTTP + TLS/SSL, providing an encrypted and authenticated connection between browser and server.

Q36. PGP (Pretty Good Privacy) uses which trust model?

Correct Answer: B) Web of Trust

Explanation: PGP relies on a decentralized 'Web of Trust' where users personally verify and sign each other's public keys, unlike S/MIME's CA-based model.

Q37. S/MIME differs from PGP mainly because S/MIME relies on:

Correct Answer: B) A CA-based PKI trust model

Explanation: S/MIME uses traditional PKI — certificates issued and signed by a trusted Certificate Authority — rather than PGP's peer-to-peer Web of Trust.

Q38. Under India's IT Act, 2000, digital signatures are:

Correct Answer: B) Legally recognized, similar to handwritten signatures

Explanation: The IT Act, 2000 gives legal recognition to digital signatures and electronic records, treating them as valid as physical signatures/documents in most cases.

Q39. Blockchain achieves tamper-resistance mainly through the use of:

Correct Answer: B) Cryptographic hashing linking each block to the previous one

Explanation: Each block contains a hash of the previous block, so altering any past block breaks the hash chain and is immediately detectable.

Q40. Which best describes the relationship between LDAP and Active Directory?

Correct Answer: B) Active Directory is Microsoft's directory service that uses the LDAP protocol

Explanation: Active Directory is Microsoft's implementation of a directory service, and it uses LDAP as the protocol to query and manage that directory data.